

Индивидуальный проект. Этап 2

Установка DVWA

Дагделен Зейнап Реджеповна

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	16

Список иллюстраций

4.1	Клонирование репозитория	9
4.2	Изменение прав доступа	9
4.3	Перемещение по директориям	10
4.4	Создание копии файла	10
4.5	Открытие файла в редакторе	10
4.6	Редактирование файл	11
4.7	Запуск mysql	11
4.8	Авторизация в базе данных	12
4.9	Изменение прав	12
4.10	Перемещение между директориями	12
4.11	Открытие файла в текстовом редакторе	13
4.12	Редактирование файла	13
4.13	Запуск arche	14
4.14	Запуск веб-приложения	14
4.15	Авторизация	15
4.16	Домашняя страница DVWA	15

Список таблиц

1 Цель работы

Приобретение практических навыков по установке DVWA.

2 Задание

1. Установить DVWA на дистрибутив Kali Linux.

3 Теоретическое введение

DVWA - это уязвимое веб-приложение, разработанное на PHP и MySQL.

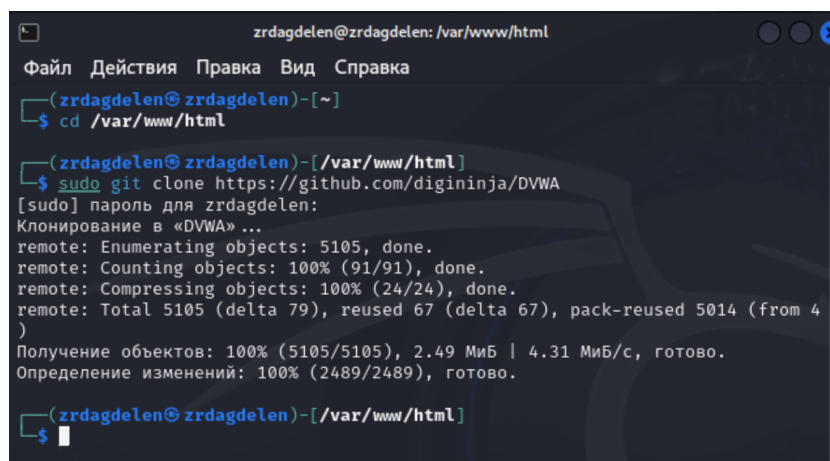
Некоторые из уязвимостей веб приложений, который содержит DVWA: - Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей. - Исполнение (внедрение) команд: Выполнение команд уровня операционной системы. - Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений. - Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение. - SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение. - Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер. - Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS. - Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

DVWA имеет четыре уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA: - Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом. - Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой

простор эксплуатации как на других уровнях. - Средний — этот уровень безопасности предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу. - Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации. [parasram?]

4 Выполнение лабораторной работы

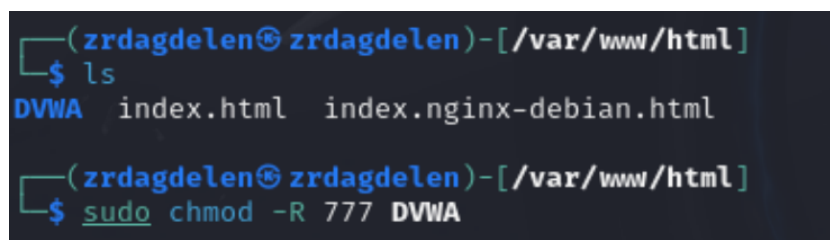
Настройка DVWA происходит на нашем локальном хосте, поэтому нужно перейти в директорию `/var/www/html`. Затем клонирую нужный репозиторий GitHub (рис. 1).



```
zrdagdelen@zrdagdelen: /var/www/html
Файл Действия Правка Вид Справка
(zrdagdelen@zrdagdelen)~]
$ cd /var/www/html
(zrdagdelen@zrdagdelen)-[/var/www/html]
$ sudo git clone https://github.com/digininja/DVWA
[sudo] пароль для zrdagdelen:
Клонирование в «DVWA» ...
remote: Enumerating objects: 5105, done.
remote: Counting objects: 100% (91/91), done.
remote: Compressing objects: 100% (24/24), done.
remote: Total 5105 (delta 79), reused 67 (delta 67), pack-reused 5014 (from 4)
Получение объектов: 100% (5105/5105), 2.49 МиБ | 4.31 МиБ/с, готово.
Определение изменений: 100% (2489/2489), готово.
(zrdagdelen@zrdagdelen)-[/var/www/html]
$
```

Рис. 4.1: Клонирование репозитория

Проверяю, что файлы скопировались правильно, далее повышаю права доступа к этой папке до 777 (рис. 2.)



```
(zrdagdelen@zrdagdelen)-[/var/www/html]
$ ls
DVWA index.html index.nginx-debian.html
(zrdagdelen@zrdagdelen)-[/var/www/html]
$ sudo chmod -R 777 DVWA
```

Рис. 4.2: Изменение прав доступа

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверить содержимое каталога (рис. 3)

```
(zrdagdelen@zrdagdelen)-[/var/www/html]
$ cd DVWA/config

(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist
```

Рис. 4.3: Перемещение по директориям

Создаем копию файла, используемого для настройки DVWA `config.inc.php.dist` с именем `config.inc.php`. Копируем файл, а не изменяем его, чтобы у нас был запасной вариант, если что-то пойдет не так (рис. 4)

```
(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$ sudo cp config.inc.php.dist config.inc.php

(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$ ls
config.inc.php  config.inc.php.dist
```

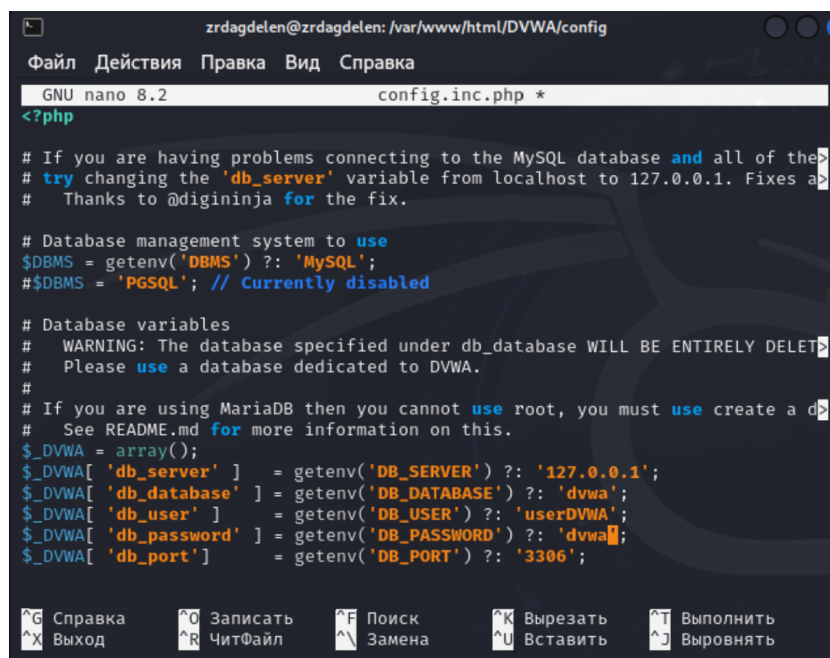
Рис. 4.4: Создание копии файла

Далее открываю файл в текстовом редакторе (рис. 5)

```
(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$ sudo nano config.inc.php
```

Рис. 4.5: Открытие файла в редакторе

Изменяю данные об имени пользователя и пароле (рис. 6)

A terminal window titled 'zrdagdelen@zrdagdelen: /var/www/html/DVWA/config' shows the nano 8.2 editor editing 'config.inc.php'. The file content includes comments about MySQL database connection issues, database management system settings (MySQL vs PostgreSQL), and database variables. The variables are set to: db_server: 127.0.0.1, db_database: dvwa, db_user: userDVWA, db_password: dvwa, and db_port: 3306. A warning message states that the database specified will be entirely deleted. The bottom of the window shows nano editor shortcuts in Russian: ^G Справка, ^X Выход, ^O Записать, ^R ЧитФайл, ^F Поиск, ^\ Замена, ^K Вырезать, ^U Вставить, ^T Выполнить, ^J Выворнять.

```
zrdagdelen@zrdagdelen: /var/www/html/DVWA/config
GNU nano 8.2 config.inc.php *
<?php

# If you are having problems connecting to the MySQL database and all of the
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes ap
# Thanks to @digininja for the fix.

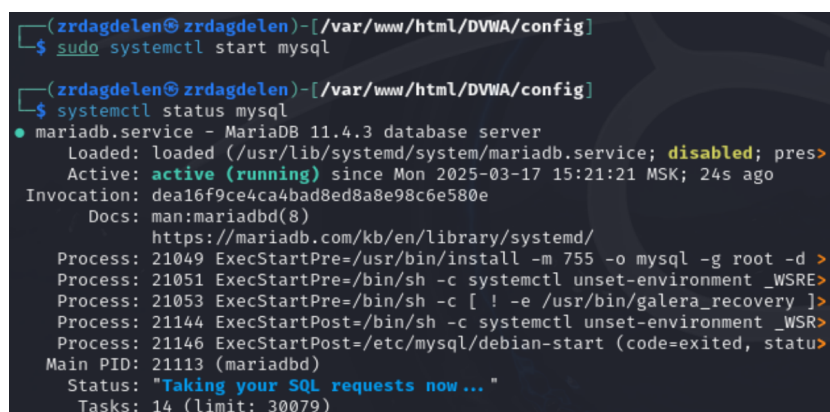
# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
#$DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a d
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA['db_user'] = getenv('DB_USER') ?: 'userDVWA';
$_DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'dvwa';
$_DVWA['db_port'] = getenv('DB_PORT') ?: '3306';

^G Справка  ^O Записать  ^F Поиск    ^K Вырезать  ^T Выполнить
^X Выход    ^R ЧитФайл  ^\ Замена   ^U Вставить  ^J Выворнять
```

Рис. 4.6: Редактирование файл

По умолчанию в Kali Linux установлен mysql, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (рис. 7)

A terminal window shows the execution of 'sudo systemctl start mysql' followed by 'systemctl status mysql'. The output indicates that the MariaDB service is loaded and active (running) since Mon 2025-03-17 15:21:21 MSK. It also shows the invocation details and the status of the main PID (21113) as 'Taking your SQL requests now...'. Tasks are listed as 14 (limit: 30079).

```
(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$ sudo systemctl start mysql

(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$ systemctl status mysql
● mariadb.service - MariaDB 11.4.3 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled; pres>
   Active: active (running) since Mon 2025-03-17 15:21:21 MSK; 24s ago
   Invocation: deal6f9ce4ca4bad8ed8a8e98c6e580e
      Docs: man:mariadb(8)
            https://mariadb.com/kb/en/library/systemd/
   Process: 21049 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root -d >
   Process: 21051 ExecStartPre=/bin/sh -c systemctl unset-environment _WSRE>
   Process: 21053 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recovery ]>
   Process: 21144 ExecStartPost=/bin/sh -c systemctl unset-environment _WSR>
   Process: 21146 ExecStartPost=/etc/mysql/debian-start (code=exited, statu>
   Main PID: 21113 (mariabdd)
   Status: "Taking your SQL requests now..."
   Tasks: 14 (limit: 30079)
```

Рис. 4.7: Запуск mysql

Авторизируюсь в базе данных от имени пользователя root. Появляется командная строка с приглашением “MariaDB”, далее создаем в ней нового пользователя, используя учетные данные из файла config.inc.php (рис. 8)

```
(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.4.3-MariaDB-1 Debian n/a

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement
.

MariaDB [(none)]> create user 'userDVWA'@'127.0.0.1' identified by "dvwa";
Query OK, 0 rows affected (0,011 sec)

MariaDB [(none)]>
```

Рис. 4.8: Авторизация в базе данных

Теперь нужно пользователю предоставить привилегии для работы с этой базой данных (рис. 9)

```
MariaDB [(none)]> grant all privileges on dvwa.* to 'userDVWA'@'127.0.0.1' identified by "dvwa";
Query OK, 0 rows affected (0,009 sec)

MariaDB [(none)]> exit
Bye

(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$
```

Рис. 4.9: Изменение прав

Необходимо настроить сервер apache2, перехожу в соответствующую директорию (рис. 10)

```
(zrdagdelen@zrdagdelen)-[/var/www/html/DVWA/config]
$ cd /etc/php/8.2/apache2

(zrdagdelen@zrdagdelen)-[/etc/php/8.2/apache2]
$
```

Рис. 4.10: Перемещение между директориями

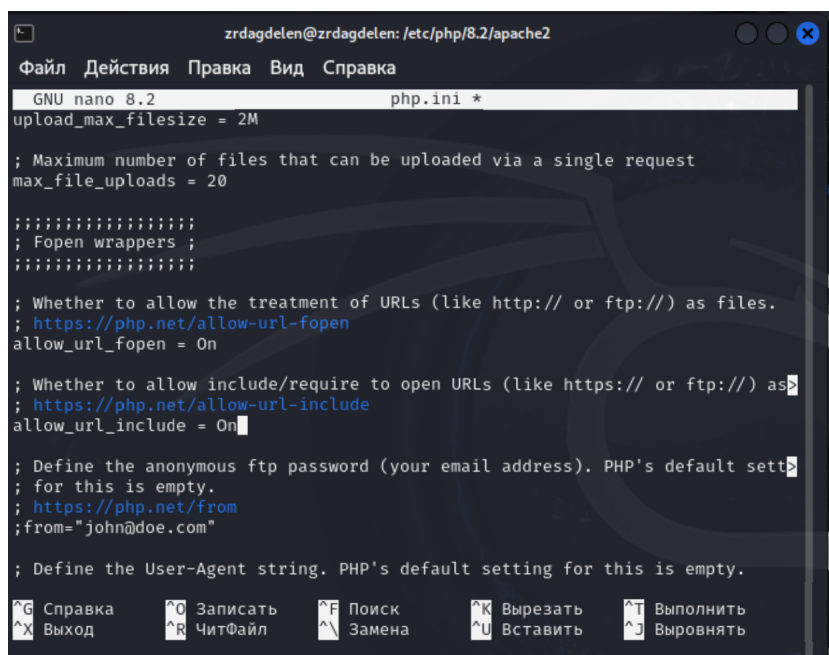
В файле `php.ini` нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе (рис. 11)

```
(zrdagdelen@zrdagdelen)-[/etc/php/8.2/apache2]
$ sudo nano php.ini

(zrdagdelen@zrdagdelen)-[/etc/php/8.2/apache2]
$
```

Рис. 4.11: Открытие файла в текстовом редакторе

В файле параметры `allow_url_fopen` и `allow_url_include` должны быть поставлены как `On` (рис. 12)



```
zrdagdelen@zrdagdelen: /etc/php/8.2/apache2
Файл Действия Правка Вид Справка
GNU nano 8.2 php.ini *
upload_max_filesize = 2M

; Maximum number of files that can be uploaded via a single request
max_file_uploads = 20

;;;;;;;;;;;;;;;;;
; Fopen wrappers ;
;;;;;;;;;;;;;;;;;

; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; https://php.net/allow-url-fopen
allow_url_fopen = On

; Whether to allow include/require to open URLs (like https:// or ftp://) as
; https://php.net/allow-url-include
allow_url_include = On

; Define the anonymous ftp password (your email address). PHP's default sett
; for this is empty.
; https://php.net/from
;from="john@doe.com"

; Define the User-Agent string. PHP's default setting for this is empty.

^G Справка    ^O Записать   ^F Поиск     ^K Вырезать  ^T Выполнить
^X Выход      ^R ЧитФайл   ^\ Замена    ^U Вставить  ^J Выводить
```

Рис. 4.12: Редактирование файла

Запускаем службу веб-сервера apache и проверяем, запущена ли служба (рис. 13)

```
(zrdagdelen@zrdagdelen)-[/etc/php/8.2/apache2]
$ sudo systemctl start apache2

(zrdagdelen@zrdagdelen)-[/etc/php/8.2/apache2]
$ systemctl status start apache2
Unit start.service could not be found.
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; pres>
   Active: active (running) since Mon 2025-03-17 15:41:57 MSK; 46s ago
 Invocation: eb00e724e4f441c49f3b63cb632d5fd5
    Docs: https://httpd.apache.org/docs/2.4/
   Process: 31895 ExecStart=/usr/sbin/apachectl start (code=exited, status=>
  Main PID: 31911 (apache2)
     Tasks: 6 (limit: 4557)
    Memory: 20.2M (peak: 20.7M)
       CPU: 158ms
    CGroup: /system.slice/apache2.service
           └─31911 /usr/sbin/apache2 -k start
             31914 /usr/sbin/apache2 -k start
             31915 /usr/sbin/apache2 -k start
             31916 /usr/sbin/apache2 -k start
             31917 /usr/sbin/apache2 -k start
             31918 /usr/sbin/apache2 -k start

map 17 15:41:57 zrdagdelen systemd[1]: Starting apache2.service - The Apache>
map 17 15:41:57 zrdagdelen systemd[1]: Started apache2.service - The Apache >
lines 1-21/21 (END)
```

Рис. 4.13: Запуск архе

Мы настроили DVWA, Apache и базу данных, поэтому открываем браузер и запускаем веб-приложение, введя 127.0.0/DVWA (рис. 14)

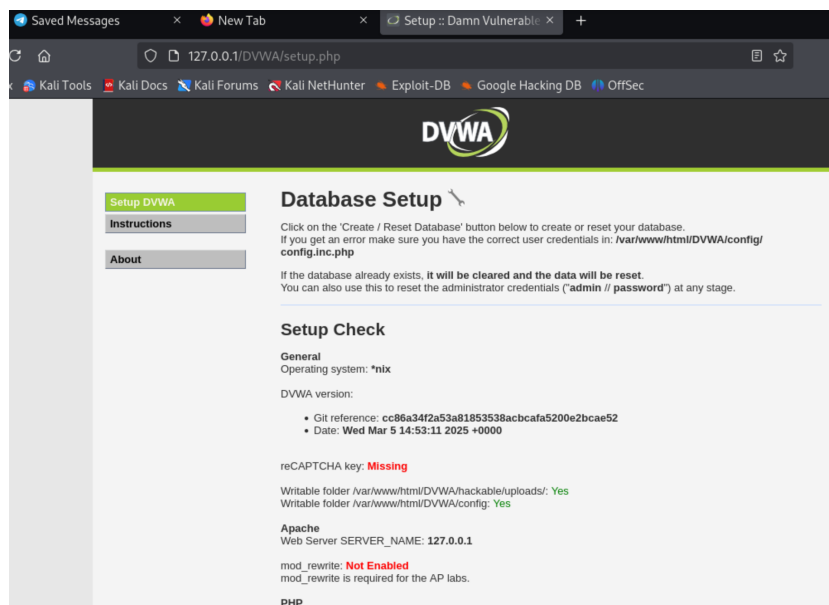


Рис. 4.14: Запуск веб-приложения

Прокручиваем страницу вниз и нажимаем на кнопку create\reset database. Авторизуюсь с помощью предложенных по умолчанию данных (рис. 16)

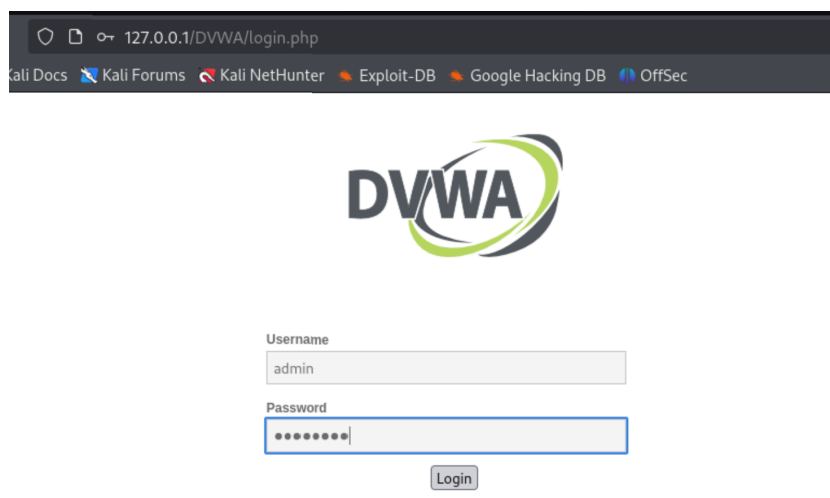


Рис. 4.15: Авторизация

Оказываюсь на домашней странице веб-приложения, на этом установка окончена (рис. 17)

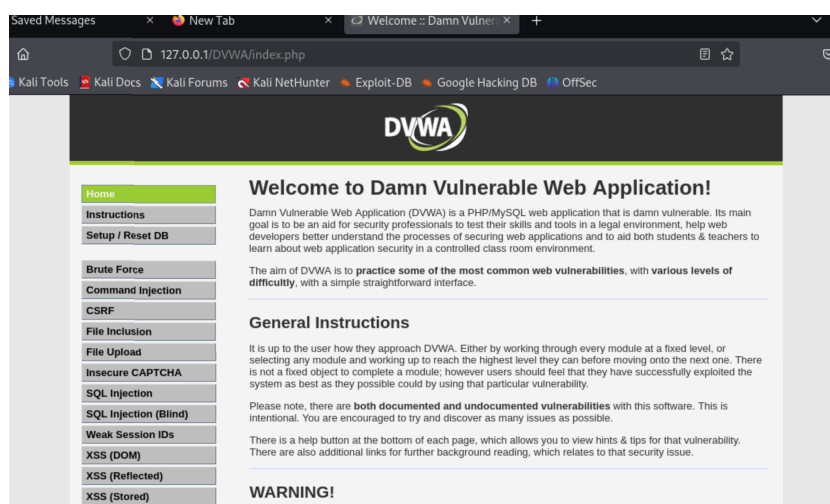


Рис. 4.16: Домашняя страница DVWA

5 Выводы

Приобрела практические навыки по установке уязвимого веб-приложения DVWA.